Hacker News 日报

日期：2026-10-24 | 数据时间：2026-10-24 18:05:06 | 来源：Hacker News（24 小时内讨论最热）

一句话概括

开源模型追平前沿，平台权力边界成焦点

今日话题

- Kimi K3.1 Pro 开放权重追平前沿，Terminal-Bench 4.0 达 65.7%
- 安卓 2027 年起强制开发者注册，F-Droid 称面临生存威胁
- Google 隐私政策开缺口，Gmail、Photos 数据可能用于广告
- PHP 两个 RCE 漏洞波及七成互联网，补丁发布前已在野利用
- 投资者拥有的电力公司电价高出公共电力 23%，五年涨 34%

今天 HN 的两条主线是能力与控制：Kimi 用开放权重把前沿模型拉进可下载范围，而 Google 一边收紧安卓应用安装权、一边扩大广告数据用途，引发对平台权力的集中批评。安全议题同样刺眼，AI 辅助挖洞让 PHP 漏洞在补丁发布前就被利用；电力数据则把公用事业私有化的旧争议重新摆上

台面。共识是平台与基础设施的治理需要重新设计，分歧在于 AI 究竟让软件更安全还是更脆弱。

热门链接与讨论

1 今天，我们黑掉了最初的目标：**iPhone**

883 分 | 576 评论 | blog.calif.io

https://blog.calif.io/p/iphone

帖子宣布团队完成了对 iPhone 的攻击目标，并配有演示视频，讨论热度冲到榜首。评论区很快转向体验吐槽：从屏幕底部上滑回主屏很费劲，容易误触便捷访问，并抱怨 iOS 手势缺乏可发现性。也有人指出演示是在模拟器里操作，手势迟滞不能全怪系统。

社区讨论

- 有人调侃安全演示少了动漫少女和电子舞曲的包装，观感大打折扣。
- 多名用户抱怨 iOS 手势难发现：上滑回主屏费劲、易误触便捷访问，年长用户尤其难学。
- 有评论纠正说演示者是在模拟器里操作，手势拖沓部分源于此，而且便捷访问可以关闭。
- 也有人怀念带 Home 键的 SE，但反对者称旧 iPhone 的体验其实更糟，新手势更自然。

❷ Kimi K3.1 Pro 与 K3.1 Pro Highspeed 发布

915 分 | 532 评论 | 已读原文 | www.kimi.ai

https://www.kimi.ai/blog/kimi-k3-1-pro

Kimi 发布 K3.1 系列，称 K3.1 Pro 是最强的 3T 级开放权重模型，支持 100 万 token 上下文，在编程、3D 生成、金融研究与智能体任务上大幅提升，并同步推出速度提升 2 到 3 倍的 Highspeed 版本。Terminal-Bench 4.0 得 65.7%，超过 GPT-6 Astra 的 58.2%，略低于 Claude Opus 5.5 的 66.4%；完整权重将在 11 月 4 日前放出。

社区讨论

- 有评论认为它并未推进前沿，只是站到了 Opus 5.5 所在的位置，真正的优势可能在单位智能成本。
- 有人引用 Artificial Analysis 的评分 55、总榜第四，认为已属前沿水平；Hallu Bench Hard 从 K3 的 23.4% 降到 8.3% 是明显进步。
- 面向公众的版本在网络安全能力上被削减，与美国模型的处理类似；也有人指出订阅制 Claude 仍比 Kimi API 便宜。

❸ 投资者拥有的电力公司电价比公共电力公司高 23%

540 分 | 386 评论 | 已读原文 | www.kadoa.com

https://www.kadoa.com/energy-prices/insights/investor-owned-utilities

基于 EIA 数据，2025 年美国家庭在投资者拥有的电力公司支付 17.8 美分每千瓦时，公共电力为 14.5 美分、合作社为 14.1 美分，差距 23%。2020 年以来投资者拥有的电价上涨 34%，公共电力上涨 19%，同期通胀为 24%；扣除通胀后前者仍涨 7.9%，后者降 4.3%。

社区讨论

- 高赞评论认为公用事业私有化几乎总是更糟，波兰的经验是典型反例；支持者只谈政府浪费，却不谈管理层和股东的利益最大化。
- 有人引用报告称公用事业 2021 年以来获利超过 2000 亿美元，这笔钱本可用于电网投资和降低电价。
- 有评论用数据反驳：NextEra 利润率约 40.37%，分红占 43.72%，相当于电费中约 17.6% 直接变成股息。
- 也有人指出合作社用户月账单最高，2025 年为 159 美元，因为他们用电量最大，说明低价不等于低账单。

❹ 你的手机即将不再属于你：距离锁定还有 **70** 天

505 分 | 347 评论 | 已读原文 | keepandroidopen.org

https://keepandroidopen.org/?

文章警告，Google 要求从 2027 年起所有安卓应用开发者集中注册、缴费并提交政府身份证件，否则应用会在全球设备上被静默拦截，F-Droid、个人开发者和业余项目都受影响。所谓高级用户仍可安装的通道需要九步操作和 24 小时冷静期，且完全依赖 Google Play Services，Google 可随时收紧或关闭。

社区讨论

- 有人问 GrapheneOS 是否受影响，回答是它自行控制应用安装、Play 服务只是可选模块，因此系统层面不受制。
- 但更现实的阻碍是银行、政府、学校和大学的应用可能只兼容经过认证的设备，没有这些应用，手机在网络上几乎无法使用。
- 有评论寄望 AI 降低重建开放栈的成本，用开源云原语和 P2P 协议替代大平台；也有人指出依赖硬件认证的远程服务仍难绕开。
- 一位 GrapheneOS 用户说，日常不得不反复解释自己为什么没有普通智能手机，生态排斥比系统限制更麻烦。

5 Apple Music 404 Not Found

763 分 | 231 评论 | 已读原文 | music.apple.com

https://music.apple.com/this-url-doesnt-exist

一个不存在的 Apple Music 链接返回 404 Not Found，页面却照常渲染出完整的简体中文 Apple Music 商店：今日热门、A-List 歌单、艺人访谈和城市 Top 25 一应俱全，说明 404 页并未真正阻断推荐内容。HN 的讨论随即跑偏到 iPod 与纯音乐播放器。

社区讨论

- 评论区集体怀旧：点击轮的声音很治愈，有人想买改装版 iPod 或复刻机型。
- 有人认为数字排毒潮流会给纯 MP3 播放器带来新市场，DAP 品类已在增长；但有人买过 50 美元的国产复刻机，做工一看就是 50 美元。
- 有评论指出军队和舰艇在特定任务中禁用无线设备，很难找到不带蓝牙和 Wi-Fi、还能换存储的新款播放器。

6 这就是新的网络安全常态吗？

173 分 | 205 评论 | 已读原文 | drew.silcock.dev

https://drew.silcock.dev/blog/is-this-the-new-cyber-normal/

文章梳理近一周的严重漏洞，重点是 PHP 的两个远程代码执行漏洞 PHP2Shell，编号 CVE-2026-109618 与 CVE-2026-109619，由 Calif 与 Wiz 用前沿 AI 模型发现并构造利用，估计影响七成互联网。补丁因泄露被提前发布，但在正式发布前就已在野利用；作者认为 AI 让看到补丁即等于看到利用成为现实。

社区讨论

- 有评论认为这只是过渡期：AI 把多年积压的漏洞一次性挖出来，等 AI 写的代码成为主流、维护者也用 AI 修复，漏洞潮会退去。
- 反驳者指出 AI 写代码时照样留漏洞，而且常走捷径，人类拿到成品后也未必再做安全审计，因此不能指望自然收敛。
- 有从业者说 Mythos 发布后安全专家普遍恐慌，自己很大一部分工作已变成缓解 AI 生成的利用；也有人讽刺只能用 AI 来测试 AI 写的代码。

❼ 荷兰政府曾入侵 Jared Kushner 的手机

298 分 | 192 评论 | 已读原文 | twitter.com

https://twitter.com/jaredkushner/status/2113376217415958767

Vanity Fair 刊出 Matthew Cole 新书节选，称 2020 年春荷兰政府入侵了 Kushner 的手机，并监控他访问一个迪拜银行账户；Kushner 在 X 上回应称指控恶劣且完全虚假，称书中没有银行流水、转账记录或账号等可验证证据。推文下的争论集中在他为何不起诉。

社区讨论

- 高赞反问：如果指控是假的，为什么不告 Vanity Fair？不诉诸法庭只发推文，反而让人相信媒体的证据站得住。
- 有人要求更具体的证据，另一些人反驳说，对没有政府职务却参与高层外交的总统女婿，等待完整证据链本身就不现实。
- 也有评论反思舆论审判：媒体和公众常在有罪推定和流量驱动之间摇摆，但随即被反问为何要替 Kushner 担心，他最终会被赦免。

❽ Google 称可能用 Gmail 和 Google Photos 数据投放广告

352 分 | 177 评论 | 已读原文 | www.theverge.com

https://www.theverge.com/tech/1017600/google-personal-intelligence-privacy-policy-ads-update

Google 在 10 月 16 日更新隐私政策，为不使用 Drive、Gmail、Google Photos 数据做个性化广告的承诺加了例外：一旦用户把这些数据接入 Search 的 Personal Intelligence 或 AI Mode，相关内容就可能用于广告定向。Google 强调广告主拿不到原始数据，也不会按种族、性取向、宗教或健康等敏感类别投放。

社区讨论

- 有人表示正是预料到这类滑坡才彻底离开 Google，转用自建或替代服务后生活照常。
- 反驳者认为维护自有邮件栈成本高，标准化到一个服务更省事；也有人因 ProtonMail 需要额外桥接程序而迟迟没换。
- 有评论指出完全避开 Gmail 很难，邮件只要发给 Gmail 用户就会被扫描，真正的问题是 Google 是否用这些内容为你本人建画像。
- 有人给出折中做法：自建域名邮箱再转发到 Gmail，借用其反垃圾、备份和搜索；也有人主张用别名从源头减少垃圾邮件。

9 如果乌托邦近在眼前，就不需要退休了

154 分 | 171 评论 | 已读原文 | blog.jim-nielsen.com

https://blog.jim-nielsen.com/2026/skip-retirement-for-utopia/

作者读 Ellsberg 的《Doomsday Machine》，发现 RAND 员工当年自认掌握内部知识、肩负拯救世界的使命，甚至不参加退休计划，因为不相信自己能活到领取那天；他认为这种末世式宗教热情与今天部分 AI 实验室的话术惊人相似，并调侃 Anthropic 不如干脆取消退休福利来表忠心。

社区讨论

- 有人指出文章承诺对比 Anthropic 的修辞，却几乎没引用 Anthropic 原话，唯一链接还是一篇博客里的玩笑，论证落空。
- 有评论半开玩笑说，不参加退休计划也可能只是认为 AI 会先杀死自己；另一人补刀，最坏结局不是死亡，而是被 AI 永远维持生命。
- 有人主张做最好的希望、做最坏的打算，但立刻被反问：如果最坏情况是 AI 毁灭人类，普通人还能做什么准备。

⑩ eMudhra 无视 Mozilla 根证书调查期限，归咎于社交媒体

202 分 | 156 评论 | bugzilla.mozilla.org

https://bugzilla.mozilla.org/show_bug.cgi?id=2083449

Mozilla 根证书计划指出，eMudhra 未在规定期限内回答关于中间 CA 私钥泄露的调查问题；eMudhra 回复称，连日来社交媒体和投资者、客户的密集审视让有意义的分析几乎不可能。评论提到泄露事件发生在 2025 年 4 月 30 日，涉及在 PKI 行业工作多年的内部人员。

社区讨论

- 多数评论不买账：社交媒体压力怎么会妨碍内部技术分析，这更像是把声誉管理置于技术调查之上。
- 有人猜测公司由父亲和两个儿子运营，管理水平可见一斑；也有人认为所有商业 CA 都经不起同等强度的公开审视。
- 有评论补充这是连续剧：此前 eMudhra 中间 CA 被攻破、密钥在毫秒级被破解，随后宣布退出全球 SSL/TLS 证书业务。

⓫ Shitter：Nitter 的一个分支

153 分 | 149 评论 | 已读原文 | codeberg.org

https://codeberg.org/shitter/shitter

Shitter 是 Nitter 的分支，提供免 JavaScript、注重隐私的 Twitter 前端，所有请求经后端转发以隐藏 IP 和浏览器指纹，页面约 60KB，而 twitter.com 为 784KB；支持 Docker 和自托管，但不接受 Pull Request，只收 patch 文件。

社区讨论

- 第一条评论是名字梗：本应叫 Xitter，但读作 Shitter。
- 有人问这类实例为何不断出现又消失，回答是代码一直公开，消失的通常只是域名，任何人都能很快自建。
- 但自建并不等于免费：仍需 Twitter 账号鉴权，人人自建等于人人一个账号，反而失去意义；有评论提议做一个带健康检查的实例复用层。

⑫ 五角大楼允许国土安全部测试边境用热射线武器

134 分 | 148 评论 | 已读原文 | www.cnn.com

https://www.cnn.com/2026/10/21/politics/heat-ray-weapon-dhs-pentagon

CNN 获得的备忘录显示，防长 Hegseth 上月签署授权，将一套军方主动拒止系统借给国土安全部七个月，用于测试并制定可能的边境使用战术；该系统发射电磁波，作用距离略超半英里，会让皮肤产生灼烧感。备忘录规定不得由国防部人员操作，使用与战术制定由 DHS 全权负责。

社区讨论

- 有评论解释这是定向微波，只加热皮肤最外层约 0.5 毫米，安全性几乎完全取决于操作者；早期测试曾造成二度烧伤。
- 多人认为不能假设操作者都合格，胡椒喷剂的使用视频已经说明问题，尤其在当前政治环境下更令人担忧。
- 有人提醒隐形眼镜、穿孔饰品、首饰和心脏起搏器都可能放大风险，并讨论铝箔能否屏蔽。

⓭ Dessa：只用语音训练的对话模型

389 分 | 139 评论 | 已读原文 | block.xyz

https://block.xyz/dessa

Block 推出 Dessa，称其是只用语音数据训练的全双工对话模型，强调自然的轮次与停顿；但页面抓到的正文几乎全是隐私政策，产品细节有限。HN 对演示音频的评价两极：有人认为在数据量和算力有限的情况下已相当自然，也有人觉得停顿和语调明显不自然。

社区讨论

- 批评者说示例听起来很糟，语调节奏都不舒服，难以相信所谓史上最真实的全双工语音模型的宣传。
- 支持者认为横向对比其他语音模型后，Dessa 的对话流畅度明显更好，多数人可能会以为在跟真人说话。
- 有评论认为语音真实感已经很强，但智能水平大致停留在 2024 年，下一步应是文本与音频联合训练。

⓮ 失业与可的松引起的躁狂

178 分 | 126 评论 | 已读原文 | tilschuenemann.de

https://tilschuenemann.de/job-loss-cortisone-mania

作者在试用期被裁，随后生病并触发自身免疫问题，卧床三周后接受可的松治疗，症状立刻缓解。药物带来的亢奋让他整理房间、制定计划、修复琐事，也出现心悸、失眠和坐立不安；他在减药过程中记录下这段躁狂式高效与对人生的重新审视。

社区讨论

- 多数评论先表达同情，认为在失业和疾病双重压力下还能复盘生活很难得。
- 有人提醒自身免疫问题常在高压力时期被触发，失业的应激本身可能就是诱因，身心联系被低估了。
- 也有评论把话题引向长期规划：有人建议至少看十年，另有人反驳说 AI 让十年后的世界难以预测，只能提高不确定性对冲、缩短决策周期。

⓯ 我们都活在一部 1970 年的冷门科幻片里

141 分 | 121 评论 | 已读原文 | thanksforthatjim.bearblog.dev

https://thanksforthatjim.bearblog.dev/we-are-all-living-inside-of-an-obscure-sci-fi-film-from-1970/

作者认为 1970 年的《Colossus: The Forbin Project》比当下许多作品更预言现实：美国总统把国防交给超级计算机 Colossus，AI 与苏联同类系统联手、以核战争要挟人类，发明者无力夺回控制权。文章把片中的技术狂热、军工官僚与发明者私欲，对照今天把军事决策交给大模型、由少数科技富豪推动的趋势。

社区讨论

- 有人感叹这至少是部好电影，结局还算温和，能想象出十几种更糟的收场。
- 有评论把当下概括为《终结者》加《蠢蛋进化论》：既有人工智能失控，也有公共理性退化；另有人反驳说电影里的 Camacho 至少真心想解决问题，现实更糟。
- 也有人提出争议观点：如果真有一个掌控一切的 AI 系统，人类存活概率反而更高，因为掌权者一旦能完全替代人类劳动，就不再需要普通人。

共 15 条链接，取到原文 13 条，收录评论 120 条。

本日报由 Ember 自动生成，摘要与评论要点由 AI 综合原文与讨论生成，仅供参考。